Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
☐	☑	Least Privilege
☐	☑	Disaster recovery plans
☐	☑	Password policies
☐	☑	Separation of duties
☑	☐	Firewall
☐	☑	Intrusion detection system (IDS)
☐	☑	Backups
☑	☐	Antivirus software
☐	☑	Manual monitoring, maintenance, and intervention for legacy systems
☐	☑	Encryption
☐	☑	Password management system
☑	☐	Locks (offices, storefront, warehouse)
☑	☐	Closed-circuit television (CCTV) surveillance
☑	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☑	Only authorized users have access to customers' credit card information.
☐	☑	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☑	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☑	E.U. customers' data is kept private/secured.
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☑	Ensure data is properly classified and inventoried.
☑	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☑	User access policies are established.
☐	☑	Sensitive data (PII/SPII) is confidential/private.

- [x] [ ] Data integrity ensures the data is consistent, complete, accurate, and has been validated.
- [ ] [x] Data is available to individuals authorized to access it.

My Recommendations:

Botium Toys currently has a weak security framework in place and needs to implement multiple controls to significantly strengthen their organization and guarantee confidentiality. I highly encourage the company to incorporate the following controls: least privilege, disaster recovery plans, password policies, separation of duties, an intrusion detection system, backups, manual monitoring/maintenance, encryption, and a password management system.

Botium Toys should also reevaluate their compliance to standards and consider the following: implementing least privilege, utilizing encryption, classifying current assets, and enforcing separation of duties to better adhere to PCI DSS, GDPR, and SOC best practices.

By following these recommendations, Botium Toys would have a strong security framework in place that adheres to all controls, compliance needs, and best practices.